06-2-policy-test-output

accounts-api security assessment · generated from the repository, not hand-edited

```
# 06-2-policy-test-output.txt
#
# Section 6 deliverable: captured test output showing the bad manifest
# rejected. 39 kyverno assertions across three fixtures, plus the Terraform
# and waiver negative fixtures failing as designed.
#
# Assembled by scripts/build-submission.py from the repository.

================================================================================
SOURCE: test-output/kyverno-test.txt
================================================================================
Loading test  ( policy/kyverno/tests/kyverno-test.yaml ) ...
  Loading values/variables ...
  Loading policies ...
  Loading resources ...
  Loading exceptions ...
  Applying 9 policies to 8 resources ...
  Checking results ...

|────────|──────────────────────────────────|──────────────────────────────────|──────────
──────────────────|────────|────────|
| [40;32mID (39) [0m | [40;32mPOLICY                            [0m | [40;32mRULE
[0m | [40;32mRESOURCE                         [0m | [40;32mRESULT[0m | [40;32mREASON[0m |
|────────|──────────────────────────────────|──────────────────────────────────|──────────
──────────────────|────────|────────|
| 1        | disallow-host-namespaces           | autogen-host-namespaces           |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 2        | disallow-host-namespaces           | autogen-host-namespaces           |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 3        | disallow-hostpath                  | autogen-no-hostpath-volumes       |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 4        | disallow-hostpath                  | autogen-no-hostpath-volumes       |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 5        | require-restricted-securitycontext | autogen-run-as-non-root           |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 6        | require-restricted-securitycontext | autogen-no-privilege-escalation   |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 7        | require-restricted-securitycontext | autogen-drop-all-capabilities     |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 8        | require-restricted-securitycontext | autogen-seccomp-runtime-default   |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 9        | require-restricted-securitycontext | autogen-seccomp-runtime-default   |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 10       | require-restricted-securitycontext | autogen-run-as-non-root           |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 11       | require-restricted-securitycontext | autogen-no-uid-zero               |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 12       | require-restricted-securitycontext | autogen-no-uid-zero               |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 13       | require-image-digest               | autogen-image-must-be-digest      |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 14       | require-image-digest               | autogen-image-must-be-digest      |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 15       | restrict-registries                | autogen-allowed-registries        |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 16       | disallow-secrets-as-env            | autogen-no-secret-envfrom         |
Deployment/accounts-api-legacy  | Pass   | Ok     |
```

```
| 17       | disallow-secrets-as-env            | autogen-no-secret-envfrom          |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 18       | require-resource-limits            | autogen-limits-required            |
Deployment/accounts-api-legacy  | Pass   | Ok     |
| 19       | restrict-rbac-wildcards            | no-wildcard-verbs                  |
Role/accounts-api-legacy        | Pass   | Ok     |
| 20       | restrict-rbac-wildcards            | secrets-need-named-resources       |
Role/accounts-api-legacy        | Pass   | Ok     |
| 21       | disallow-host-namespaces           | autogen-host-namespaces            |
Deployment/accounts-api         | Pass   | Ok     |
| 22       | disallow-hostpath                  | autogen-no-hostpath-volumes        |
Deployment/accounts-api         | Pass   | Ok     |
| 23       | require-restricted-securitycontext | autogen-run-as-non-root            |
Deployment/accounts-api         | Pass   | Ok     |
| 24       | require-restricted-securitycontext | autogen-no-privilege-escalation    |
Deployment/accounts-api         | Pass   | Ok     |
| 25       | require-restricted-securitycontext | autogen-drop-all-capabilities      |
Deployment/accounts-api         | Pass   | Ok     |
| 26       | require-restricted-securitycontext | autogen-seccomp-runtime-default    |
Deployment/accounts-api         | Pass   | Ok     |
| 27       | require-image-digest               | autogen-image-must-be-digest       |
Deployment/accounts-api         | Pass   | Ok     |
| 28       | restrict-registries                | autogen-allowed-registries         |
Deployment/accounts-api         | Pass   | Ok     |
| 29       | disallow-secrets-as-env            | autogen-no-secret-envfrom          |
Deployment/accounts-api         | Pass   | Ok     |
| 30       | require-resource-limits            | autogen-limits-required            |
Deployment/accounts-api         | Pass   | Ok     |
| 31       | restrict-rbac-wildcards            | no-wildcard-verbs                  |
Role/accounts-api               | Pass   | Ok     |
| 32       | restrict-rbac-wildcards            | secrets-need-named-resources       |
Role/accounts-api               | Pass   | Ok     |
| 33       | require-restricted-securitycontext | autogen-no-uid-zero                |
Deployment/accounts-api         | Pass   | Ok     |
| 34       | restrict-rbac-wildcards            | no-wildcard-resources              |
Role/accounts-api               | Pass   | Ok     |
| 35       | restrict-rbac-wildcards            | no-wildcard-resources              |
Role/accounts-api-legacy        | Pass   | Ok     |
| 36       | require-restricted-securitycontext | autogen-init-containers-restricted |
Deployment/accounts-api-bypass  | Pass   | Ok     |
| 37       | require-restricted-securitycontext | autogen-init-containers-restricted |
Deployment/accounts-api         | Pass   | Ok     |
| 38       | restrict-privileged-rolebindings   | no-binding-to-super-roles          |
RoleBinding/accounts-api-bypass | Pass   | Ok     |
| 39       | restrict-privileged-rolebindings   | no-binding-to-super-roles          |
RoleBinding/accounts-api        | Pass   | Ok     |
|----------|------------------------------------|------------------------------------|----------
----------------------|--------|--------|


Test Summary: 39 tests passed and 0 tests failed

================================================================================
SOURCE: test-output/conftest-bad-fixture.txt
================================================================================
[33mWARN[0m - policy/fixtures/terraform/bad/main.tf - main - warn_rds_single_az:
aws_db_instance.accounts is single-AZ. Availability, not security; not a merge blocker.
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_cloudtrail_no_global_events:
aws_cloudtrail.org excludes global service events, so IAM, STS, CloudFront and Route53 calls are
NOT RECORDED AT ALL — the exact API calls of an identity attack. [B5]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_cloudtrail_no_validation:
aws_cloudtrail.org has no log file validation, so there is no digest chain and the log is not
tamper-evident evidence. [B5]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_cloudtrail_single_region:
```

```
aws_cloudtrail.org is single-region; an attacker operating in any other region is invisible. [B5]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_cloudtrail_unencrypted:
aws_cloudtrail.org writes unencrypted log files. [B5]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_open_ingress:
aws_security_group_rule.db_ingress allows ingress on 5432-5432 from 0.0.0.0/0. Use
source_security_group_id; a CIDR is a claim about the network, an SG id is a claim about identity.
[T3/B1]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_inline_password:
aws_db_instance.accounts sets `password`, which is stored in PLAINTEXT in Terraform state. Use
manage_master_user_password=true (RDS-managed secret) and iam_database_authentication_enabled=true
for the app path. [T3/B2]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_no_backups:
aws_db_instance.accounts has backup_retention_period=0 (attribute absent counts as 0). Minimum 7
days; a destructive attacker or a bad migration is unrecoverable below that. [T3/B4]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_no_deletion_protection:
aws_db_instance.accounts has no deletion_protection. [T3/B4]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_no_final_snapshot:
aws_db_instance.accounts has skip_final_snapshot=true. Deletion becomes irreversible. [T3/B4]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_publicly_accessible:
aws_db_instance.accounts has publicly_accessible=true. A production database holding PII must have
no public endpoint. [T3/B1]
[31mFAIL[0m - policy/fixtures/terraform/bad/main.tf - main - deny_rds_unencrypted:
aws_db_instance.accounts is unencrypted at rest. This cannot be enabled in place — it requires a
snapshot/restore/cutover — so it must be right at creation. [T3/B3]

[31m25 tests, 13 passed, 1 warning, 11 failures, 0 exceptions[0m

================================================================================
SOURCE: test-output/conftest-evasion-fixture.txt
================================================================================
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_dynamic_ingress_block:
aws_security_group.dyn builds ingress with a `dynamic` block, which cannot be statically analysed.
Use explicit aws_security_group_rule resources, or run this module through a plan-JSON gate as
well. [T3/B1 evasion]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_open_ingress:
aws_security_group_rule.v6 allows ingress on 5432-5432 from ::/0. Use source_security_group_id; a
CIDR is a claim about the network, an SG id is a claim about identity. [T3/B1]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main -
deny_rds_cluster_inline_password: aws_rds_cluster.aurora sets master_password, which lands in
Terraform state in plaintext. Use manage_master_user_password. [T3/B2]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_rds_cluster_no_backups:
aws_rds_cluster.aurora has backup_retention_period=0 (attribute absent counts as 0, minimum 7).
[T3/B4]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main -
deny_rds_cluster_no_final_snapshot: aws_rds_cluster.aurora has skip_final_snapshot=true. [T3/B4]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_rds_cluster_unencrypted:
aws_rds_cluster.aurora is unencrypted at rest. [T3/B3]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_unprovable_ingress_cidr:
aws_security_group_rule.var_cidr takes cidr_blocks from ${var.allowed_cidrs}, so this policy cannot
prove it excludes 0.0.0.0/0. Name the source security group, or inline the CIDRs. [T3/B1 evasion]
[31mFAIL[0m - policy/fixtures/terraform/evasion/main.tf - main - deny_unprovable_public:
aws_db_instance.sneaky sets publicly_accessible to ${var.public}, which cannot be evaluated from
the HCL. `= var.x` is not `= false`. Use a literal, or move the decision behind a module with its
own tested policy. [T3/B1 evasion]

[31m25 tests, 17 passed, 0 warnings, 8 failures, 0 exceptions[0m

================================================================================
SOURCE: test-output/waiver-check-invalid.txt
================================================================================
::warning::SEC-1903-wrong-approver: expires 2026-09-10 (in 6d) — renewal or fix needed this week,
ticket SEC-1903
::error::SEC-1900-expired: EXPIRED on 2026-07-26 (40d ago). The finding is live again. Fix it, or
open a renewal PR against SEC-1900 for a fresh two-person approval.
```

```
::error::SEC-1901-self-approved: self-approval — requested_by and approved_by must differ
::error::SEC-1901-self-approved: approved_by 'r.mehta@example-bank.com' is not in
waivers/APPROVERS.yaml
::error::SEC-1902-too-long: lifetime 365d exceeds the 14d cap for CRITICAL
::error::SEC-1903-wrong-approver: approved_by 'p.okafor@example-bank.com' may approve ['HIGH',
'LOW', 'MEDIUM'] — not CRITICAL
::error::SEC-1904-secret-accepted: gitleaks findings may only be waived as 'false-positive'. A real
secret is rotated, not waived.
::error::SEC-1905-lazy: ticket must be SEC-nnn (a waiver with no tracking issue is a decision
nobody revisits)
::error::SEC-1905-lazy: reason is too short to be a reason
::error::SEC-1905-lazy: compensating_control is mandatory — 'we accept it' is not a control

FAIL: 9 waiver problem(s); 6 waiver(s) examined.
```